

Mapping every risk across a \$9.7B credit union, then cutting the critical ones by 97%

A top-25 US credit union engaged Sthiros to run an enterprise-wide IT risk assessment, surfacing 1,124 risks across its technology ecosystem and cutting critical exposure by 97%.

Client
Top-25 US Credit Union

Service
Enterprise-Wide IT Risk Assessment

Sector
BFSI, Credit Union

Geography
United States

The Challenge:

When growth outpaces the risk you can see

The client manages \$9.7B in assets and 460,000+ members nationwide, with 9 critical applications, 12 hardware categories, and 5 cloud platforms. IT risk was assessed system by system, never as one picture. Auditor findings sat open. The NCUA exam clock was running.



Fragmented Risk View

No consolidated picture across 9 apps, 12 hardware types, 5 cloud platforms.



Unresolved Findings

Open external auditor gaps sat unaddressed ahead of the next exam cycle.



Access & SoD Gaps

Access and notification controls left unvalidated across core systems.



Vendor Blind Spots

SLA gaps and thin monitoring across cloud and outsourced providers.



No Evidence Trail

Risk was assumed, not tested, with no owner or timeline attached.



Exam Risk at Scale

Growth without matching governance is an NCUA examination liability.

"Expanding nationally while carrying unquantified IT risk is not a growth strategy. It is a liability. Evidence, not assumption, is what the next exam cycle demands."

The Solution:

One consolidated risk register, replacing assumption with evidence

Sthiros ran a structured enterprise-wide risk assessment across hardware, facilities, cloud, business processes, and applications, replacing fragmented, system-by-system views with one consolidated risk register.

Every risk was scored inherent to residual, mapped to existing controls, and assigned a named owner with a committed test frequency and deadline.

"A near-\$10 billion institution needed more than an audit. It needed one system to tell inherent risk from residual risk, and hand every finding to a named owner with a deadline."

The Methodology



Team Onboarding & Access

Access and onboarding secured across every in-scope system before assessment began.



Risk Register Template Design

A structured register built to hold inherent and residual scoring consistently across all three phases.



Baseline Checklist Development

Application- and process-specific checklists developed for every asset in scope.



Documentation Review

Process manuals, architecture diagrams, data flow diagrams, contracts, and past audit reports checked against actual practice.



Stakeholder Walkthroughs

137 interviews across asset managers, application owners, process owners, and IT teams validated what was on paper.



Draft Risk Register with Scoring

Impact multiplied by likelihood scored inherent risk; mapped controls determined what remained.



Review & Stakeholder Validation

Findings tested back against stakeholders before anything was finalised.



Final Risk Register Delivery

A fully documented, owner-assigned, ETA-committed register handed to management.

What This Means

Map risk before the auditor does.

Controls turn critical into rare.

Ownership beats a good register.

Outcomes

97%

Critical risk reduction

111 critical inherent risks cut to 3 residual through systematic control validation.

1,124

Risks assessed

Across every layer: hardware, facilities cloud platforms, applications.

137

Stakeholder interviews

Validating real operating controls, not documented policy alone.

100%

Audit-ready evidence

Every finding logged with a named owner, control, and committed ETA.

Get in touch

Is your enterprise still assuming, or validating?

Speak to Sthiros about what a structured risk assessment can unlock for your technology ecosystem.

Connect with us:
sthiros.com

STHIROS
Strategy. Risk. Cyber. AI.